НАО «КАРАГАНДИНСКИЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ ИМЕНИ АБЫЛКАСА САГИНОВА»

Кафедра Кибербезопасности и искусственного интеллекта

Лабораторная работа № 6

по дисциплине «Безопасность Баз данных»

Тема:«Оценка уязвимостей и классификация данных»

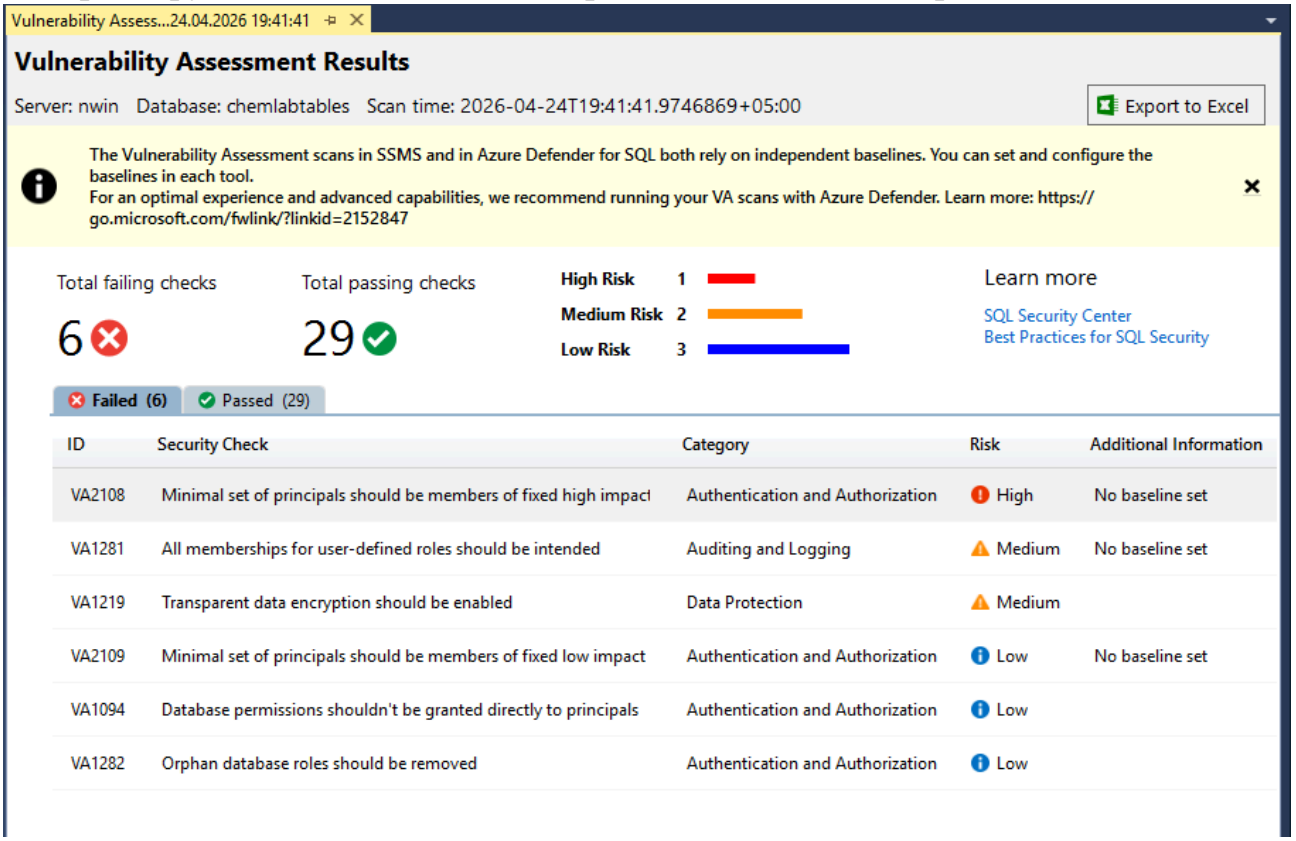
Специальность: 6В06301 – «Системы информационной безопасности»

Принял: ст.преп.
Жакина М.М.
Выполнил:
СИБ 23-7 Гутникевич Е.А.

Караганда 2026

Задания:

1. Необходимо провести оценку уязвимостей на собственной БД
2. Зафиксируйте общее количество правил и соотношение passed/failed



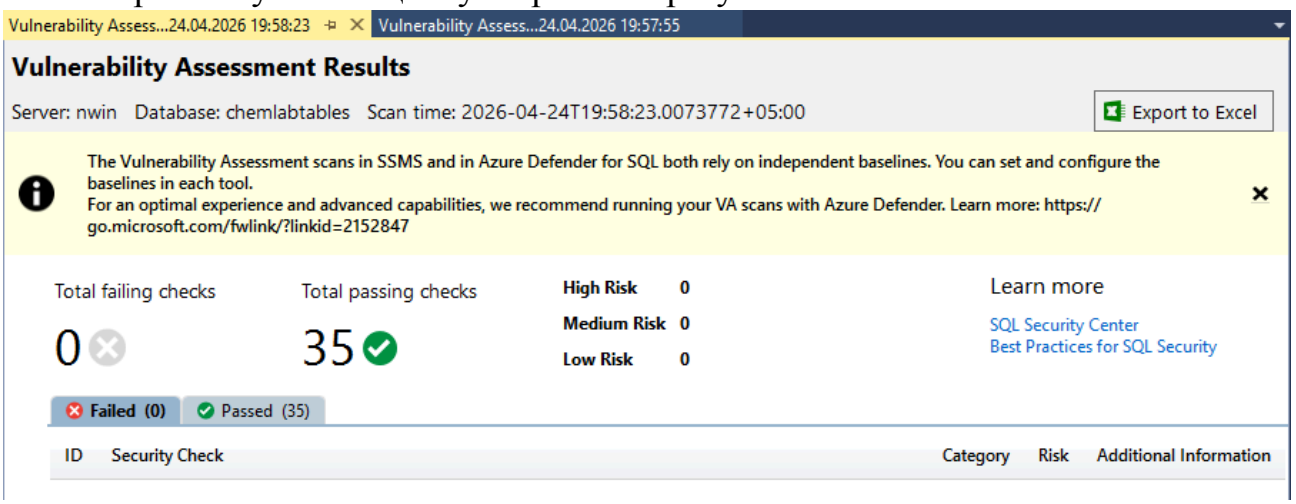
3. Составьте таблицу всех провальных правил по следующей форме:

ID правила	Уровень риска	Краткое описание	Планируемая мера
VA2108	High	Minimal set of principals should be members of fixed high impact database roles	ALTER ROLE [db_ddladmin] DROP MEMBER [AdminChem]
VA1281	Medium	All memberships for user-defined roles should be intended	ALTER ROLE [AnalystRole] DROP MEMBER [LabAnalyst] ALTER ROLE [OperatorRole] DROP MEMBER [Operator]
VA1219	Medium	Transparent data encryption should be enabled	Enable TDE on the affected database.
VA2109	Low	Minimal set of principals should be members of fixed low impact database roles	ALTER ROLE [db_datareader] DROP MEMBER [LabAnalyst]
VA1094	Low	Database permissions shouldn't be granted directly to principals	REVOKE DELETE ON dbo.[ChangeLog] FROM [AdminChem] REVOKE INSERT ON dbo.[ChangeLog] FROM [AdminChem] REVOKE SELECT ON dbo.[ChangeLog] FROM [AdminChem] REVOKE SELECT ON dbo.[ChangeLog] FROM [LabAnalyst] REVOKE UPDATE ON dbo.[ChangeLog] FROM [AdminChem]
VA1282	Low	Orphan database roles should be removed	DROP ROLE [ChemAdminRole]

4. Для каждого провального правила высокого уровня риска выполните рекомендованные меры по устранению

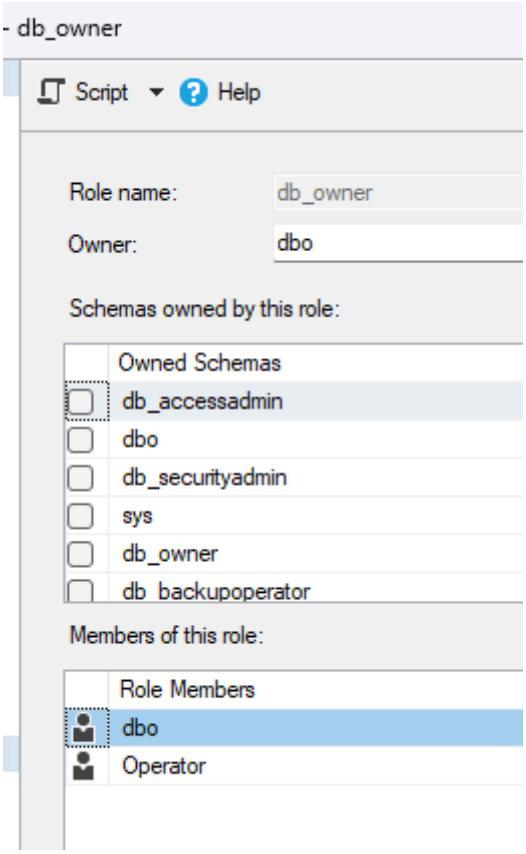
выполнено

5. Повторно запустите оценку и сравните результаты.



6. Намеренно создайте в базе данных ситуацию, нарушающую одно из правил (например, добавьте пользователя в роль db_owner или создайте учётную запись со слабым паролем)

Специальная привязка dbo_owner роли



7. Повторно запустите оценку и убедитесь, что новое нарушение зафиксировано

Vulnerability Assessment Results

Server: nwin Database: chemlabtables Scan time: 2026-04-24T20:02:32.6027410+05:00

Export to Excel

The Vulnerability Assessment scans in SSMS and in Azure Defender for SQL both rely on independent baselines. You can set and configure the baselines in each tool.
For an optimal experience and advanced capabilities, we recommend running your VA scans with Azure Defender. Learn more: https://go.microsoft.com/fwlink/?linkid=2152847

Total failing checks: 1

Total passing checks: 34

High Risk	1
Medium Risk	0
Low Risk	0

Learn more

SQL Security Center
Best Practices for SQL Security

Failed (1) | Passed (34)

ID	Security Check	Category	Risk	Additional Information
VA2108	Minimal set of principals should be members of fixed high impact da	Authentication and Authorization	High	No baseline set

Approve as Baseline | Clear Baseline

Risk
High

Status
Fail (no baseline set)

Description
SQL Server provides roles to help manage the permissions. Roles are security principals that group other principals. Database-level roles are database-wide in their permission scope. This rule checks that a minimal set of principals are members of the fixed database roles.

Impact
Fixed database roles may have administrative permissions on the system. Following the principle of least privilege, it is important to minimize membership in fixed database roles and keep a baseline of these memberships. See https://docs.microsoft.com/en-us/sql/relational-databases/security/authentication-access/database-level-roles for additional information on database roles.

Rule Query

```
SELECT user_name(sr.member_principal_id) AS [Princip
    ,user_name(sr.role_principal_id) AS [Role]
    ,type_desc AS [Principal Type]
```

Open in Query Editor Window

Actual Result

In Baseline	Principal	Role	Principal Type
✗	Operator	db_owner	SQL_USER

Remediation
Remove members who should not have access to the database role

Remediation Script

```
ALTER ROLE [db_owner] DROP MEMBER [Operator]
```

Open in Query Editor Window

Контрольные вопросы:

1. Уязвимость — это слабое место в базе данных, которое можно использовать для нарушения безопасности. Угроза — это потенциальная опасность, которая может воспользоваться уязвимостью. Инцидент — это уже произошедший случай нарушения.

2. Основные категории: ошибки конфигурации (например, включённый доступ для всех), слабая аутентификация (простой пароль), избыточные права (пользователь с правами администратора без необходимости), уязвимости кода (SQL-инъекции).

3. CVSS — это система оценки уровня опасности уязвимости. Учитывает базовые параметры (насколько легко атаковать), временные (есть ли эксплойты), и контекстные (важность системы).

4. Принцип наименьших привилегий — пользователь должен иметь только те права, которые ему нужны. Если прав больше, чем нужно, это увеличивает риск взлома или ошибок.

5. Плюсы: быстро, автоматически проверяет много параметров, находит типовые ошибки, удобно для регулярного контроля.

6. Минусы: не видит контекст, не понимает бизнес-логику, может давать ложные срабатывания. Поэтому не заменяет ручную проверку.

7. Эффективна при регулярных проверках, первичном анализе безопасности и поиске типовых уязвимостей.

8. Правила основаны на рекомендациях безопасности Microsoft, стандартах и лучших практиках настройки SQL Server.

9. Правило состоит из: идентификатора, описания проблемы, уровня риска и рекомендации по исправлению.

10. Baseline — это зафиксированное допустимое состояние. Используется, когда найденная «уязвимость» на самом деле допустима и не требует исправления.

11. В системных базах проверяются критичные настройки сервера, в пользовательских — права доступа, роли и данные.

12. Это правило проверяет избыточные права. Высокий риск, потому что даёт возможность получить полный контроль над базой.

13. Это означает «считать это нормой». Риск — можно случайно принять настоящую уязвимость и пропустить проблему.

14. Классификация данных — это определение уровня важности данных (например, персональные данные). Нужна для защиты и соблюдения требований безопасности.

15. SQL Server использует названия столбцов, типы данных, шаблоны (например email, ИИН, номера карт). Да, можно добавлять свои правила и метки.

16. Метки: Public, General, Confidential, Highly Confidential.

17. GDPR — это закон ЕС о защите персональных данных. Он требует находить и защищать такие данные, поэтому напрямую связан с классификацией.

18. Оценка уязвимостей и классификация связаны через защиту чувствительных данных. Объединяющее правило — проверка наличия защиты (например шифрования) для конфиденциальных данных.

19. Потому что она работает по шаблонам и не понимает смысл данных. Часто пропускает нестандартные названия и данные, скрытые в тексте.

20. По ним можно настроить аудит доступа к важным данным и включить шифрование именно для чувствительных столбцов.

21. Сначала исправить все с высоким риском, затем средние, потом низкие. После этого повторно проверить систему.

22. Это скрывает реальные проблемы. Я бы не согласился и предложил исправить хотя бы критические уязвимости.

23. Устранение — это исправление проблемы. Baseline — это признание, что это допустимо. Второй вариант допустим, если это осознанное и безопасное решение.

24. Они помогают понять слабые места и расставить приоритеты по защите, чтобы построить план повышения безопасности.